2024 IEEE 9th International Conference on Data Science in Cyberspace (DSC) | 979-8-3503-9136-7/24/$31.00 ©2024 IEEE | DOI: 10.1109/DSC63484.2024.00030

An Intelligent Retrieval System for Similar Information System Vulnerabilities Based on Knowledge Graph

1st Junzhe Dong
School of Economics and Management
Beijing Jiaotong University
Beijing, China
20711005@bjtu.edu.cn

2nd Shuo Geng
School of Economics and Management
Beijing Jiaotong University
Beijing, China
23120617@bjtu.edu.cn

3rd Xiong Zhang
School of Economics and Management
Beijing Jiaotong University
Beijing, China
xiongzhang@bjtu.edu.cn

***Abstract*—With the continuous improvement of information technology, information systems have been widely used in the operational processes in various organizations. While information systems provide convenience, information system vulnerabilities also threaten the privacy and security of users. When vulnerabilities occur, quickly resolving them can minimize the losses for organizations and users. At present, the determination of the types and levels of vulnerabilities in information systems is based on manual work, which requires a high level of expertise and a long time for personnel involved in resolving vulnerabilities. Automatic classification and hazard level assessment of information system vulnerabilities can help vulnerability solvers quickly evaluate vulnerabilities and determine the appropriate methods and order of vulnerability resolution based on vulnerability categories and hazard levels. Therefore, this article constructs an information system vulnerability classification model and an information system vulnerability hazard level evaluation model based on the BERT model, thereby automating this process. In addition, based on classification and hazard level prediction models, retrieving similar vulnerabilities intelligently can serve as references for vulnerability solvers, which can improve the efficiency of vulnerability resolution. Therefore, this article proposes to implement an intelligent retrieval system for similar vulnerabilities. Firstly, the BERT model is used to classify vulnerabilities and evaluate their hazard levels. Subsequently, this study constructs a knowledge graph for information system vulnerabilities using semi-structured information system vulnerability data. By combining the vulnerability classification model, the hazard level assessment model, and the information system vulnerability knowledge graphs, this study realizes an intelligent retrieval system for similar vulnerabilities.**

Keywords*—*Information system vulnerabilities, Knowledge graph, Entity recognition, system safety

I. Introduction

As shown in Figure 1, the number of information system vulnerabilities has been continuously increasing, especially since 2017, the number of information system vulnerabilities has entered an explosive growth stage. Fixing these information system vulnerabilities has become an urgent need for organizations [1, 2]. The classification of vulnerabilities and the assessment of vulnerability hazard levels can help management teams determine the right solution to vulnerabilities and the priority of handling vulnerabilities. The existing vulnerabilities can provide more references for management teams to find solutions.

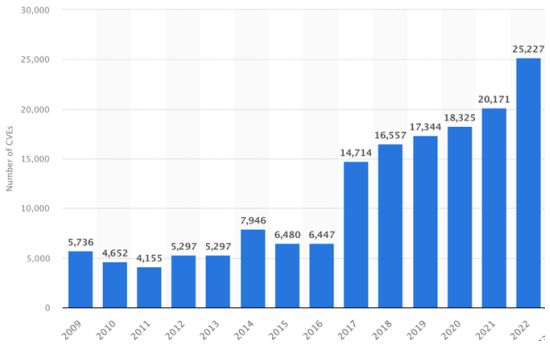


Fig. 1. Annual Increase in CVE Vulnerability Database

However, there is currently a problem of low accuracy in using machine learning to classify vulnerabilities and determine their hazard level. Therefore, manual judgment based on the vulnerability situation is still needed, which not only consumes a lot of time and effort but is also easily affected by the expertise of vulnerability solvers. After determining the classification and hazard level of vulnerabilities, due to the large number of network resources, retrieving similar vulnerabilities intelligently to provide references for solving vulnerabilities is cumbersome and also increases the difficulty of solving vulnerabilities.

This study first collects reports of information system vulnerabilities, and then constructs a BERT-based information system vulnerability classification and hazard level assessment model. Entity recognition and relationship extraction were carried out on the textual data in the information system vulnerability report, constructing an information system vulnerability knowledge graph. Based on this knowledge graph, an intelligent retrieval system for similar vulnerabilities was designed and constructed to help management teams fixing vulnerabilities efficiently and accurately.

The main contributions of this study are as follows:

- A BERT-based information system vulnerability classification and hazard level assessment model has been constructed.

979-8-3503-9136-7/24/$31.00 ©2024 IEEE
DOI 10.1109/DSC63484.2024.00030

Authorized licensed use limited to: Thammasat University. Downloaded on August 07,2026 at 05:03:11 UTC from IEEE Xplore. Restrictions apply.

- ∞ Based on information system vulnerability report data, a knowledge graph of information system vulnerabilities was constructed.
- ∞ An intelligent retrieval system for similar vulnerabilities was constructed.

II. Related Work

A. Evaluation of Vulnerability Hazards in Information Systems

The evaluation of the hazard level caused by information system vulnerabilities is related to the order in which vulnerabilities are resolved, and similarly, the evaluation of vulnerability levels is also related to vulnerability management. Therefore, there are many studies in this field. Among them, Mell et al. [3] proposed the Common Vulnerability Rating System (CVSS) in 2006, which provides an indicator for quantifying the hazard level of vulnerability. In 2007, the second version of CVSS was proposed, which addressed the shortcomings of the first version [4].

Fruhwirth and Mannisto [5] found that CVSS only considers basic indicators and cannot comprehensively evaluate the hazard level of vulnerability.

Subsequently, Farris et al. [6] believed that the evaluation indicators of CVSS did not involve indicators related to the organizational environment, making it impossible to assess vulnerability risks in a specific organizational environment in a targeted manner. Moreover, Farris et al. added two indicators to CVSS in the article, namely total vulnerability exposure and repair time.

Based on this, McQueen et al. [7] conducted a study on relevant indicators of organizational environment and proposed adding two-time indicators: vulnerability reporting time and vendor patch release time, to assess vulnerability risks in specific organizational environments.

B. Information System Vulnerability Classification

Information system vulnerability classification is an important step in solving information system vulnerabilities, and some machine learning algorithms have been applied to the classification in this field [8, 9].

In 2013, Li et al. [10] conducted a study on vulnerability classification prediction using support vector machines using vulnerability report data from the NVD vulnerability database in an article titled *Automatic Classification for Vulnerability Based on Machine Learning*. In 2017, Maryam et al. [11] proposed a vulnerability classification algorithm based on random forests, which can classify vulnerabilities into two categories: "easy to find and easy to solve" and "difficult to find and fix". Subsequently, Han et al. [12] conducted a study on system vulnerability classification using neural network methods. The results showed that the accuracy of the study was better than the previous algorithms in vulnerability classification. Hao et al. [13] proposed an algorithm based on multilayer perceptron with neural text representation for identifying vulnerabilities and predicting risk level. The experiment results show that the performance of this study is better than those using statistical text representation method.

C. Knowledge Graph of Information System Vulnerabilities

The knowledge graph of information system vulnerabilities can conveniently and effectively organize information system vulnerability information. Han et al. [14] constructed a vulnerability knowledge graph based on Common Weakness Enumeration (CWE) and developed the CWE vulnerability ontology structure. However, the knowledge graph constructed by Han et al. did not include information from the Common Vulnerability and Exposures (CVE) database, resulting in incomplete information in this knowledge graph. Therefore, Qin et al. [15] integrated information from the CVE database into the CWE vulnerability knowledge graph and improved this knowledge graph.

III. Information System Vulnerability Classification and Hazard Level Evaluation Model

A. Data Collection and Preprocessing

This study used a web crawler to collect information system vulnerability reports from a well-known information system vulnerability reporting website. This study collected 10000 information systems vulnerabilities, including vulnerability ID, vulnerability type, vulnerability hazard level, vulnerability proof, detailed vulnerability description, and vulnerability solution. Subsequently, this study cleaned data and removed data with missing values, leaving a total of 9010 pieces of data items. As shown in Figure 2, there are a total of 10 types of vulnerabilities, among which the count of high, medium, and low hazard levels in each vulnerability type is shown by blue, green, and orange-yellow columns, respectively.

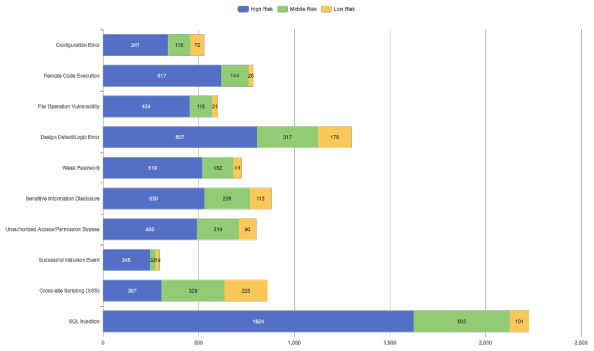


Fig. 2. Data classification statistical chart

This study preprocessed the vulnerability description in the dataset as follows. We used regularization matching to remove URLs, Chinese punctuation, single quotes, numbers, and spaces. This study created a general stop word list based on four stop word lists from Renmin University, Harbin Institute of Technology, Baidu and Sichuan University. According to this stop word list, this study deleted the stop words in the dataset.

This study utilized the Jieba to perform segmentation on the text describing vulnerabilities in detail in the information system vulnerability report. We use the BERT tokenizer Chinese encoder to encode the segmented words.

We divided the dataset into three parts: a dataset for training information system vulnerability classification models and hazard level assessment models, a dataset for testing information

Authorized licensed use limited to: Thammasat University. Downloaded on August 07,2026 at 05:03:11 UTC from IEEE Xplore. Restrictions apply.

system vulnerability classification models, and a dataset for testing information system vulnerability hazard level assessment models. The size ratio of the training and testing sets is 8:2.

B. Model construction

BERT is a large language pre-training model incorporating bidirectional encoders on top of Transformers. By utilizing this structure, BERT integrates contextual semantics into the process of word comprehension, enabling better comprehension of sentences and classification. The pre-training process of BERT consists of two parts: Masked Language Model (MLM) and Next Sentence Prediction (NSP). MLM removes a word from each sentence in the training corpus, allowing the model to predict that word, thereby improving the model's ability to understand the contextual semantic environment of the removed word. NSP enables the model to determine whether two sentences form a contextual relationship, thereby improving the model's understanding of contextual relationships.

The model has a total of 12 hidden layers, each containing 768 dimensions. Therefore, to make the model suitable for the classification of information system vulnerabilities, a layer of 768 dimensions is added to the last layer of the hidden layer of the model before fine-tuning, and the output is a fully connected layer of 10 dimensions. To apply to hazard level assessment, this article adds a layer of 768 dimensions in the last layer of the hidden layer and outputs a fully connected layer of 3 dimensions.

In terms of hyperparameter setting, this study sets the maximum sentence length of the information system vulnerability classification model to 128, batch size to 4, labels to 10, learning rate to 0.00002, and epochs to 50. In the information system vulnerability hazard level assessment model, the hyperparameter labels are set to 3.

C. Experiment analysis

This article uses three classification model metrics: accuracy, recall, and F1 to evaluate the information system vulnerability classification model and information system vulnerability hazard level evaluation model constructed in this article.

This article uses the preprocessed dataset information system vulnerability report described in subsection A for experimentation. After setting the model according to the parameters introduced in subsection B, the model is trained for 50 rounds. On the test set, the model evaluation metrics introduced in subsection C were used to evaluate the model. The evaluation results are shown in Figures 3 and 4. Figures 3 and 4 respectively show the changes in loss values during training and testing of the information system vulnerability classification model and the information system vulnerability hazard level evaluation model and show the accuracy, F1, and recall of the two models on the test set. The information system vulnerability classification model performed best with an accuracy of 61.99%, while the information system hazard level assessment model performed best with an accuracy of 65.02%.

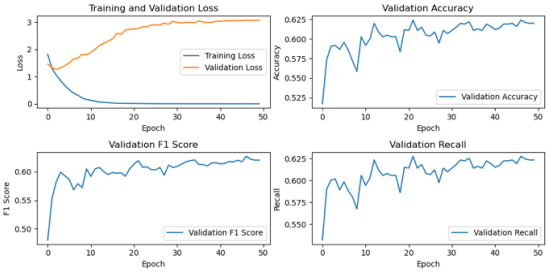


Fig. 3. Evaluation results of information system vulnerability classification model

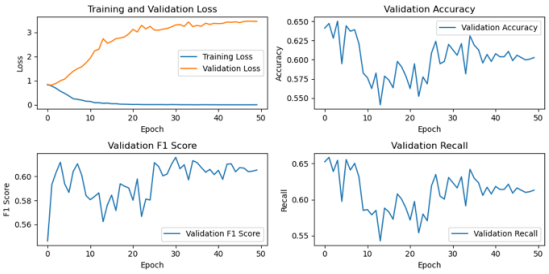


Fig. 4. Evaluation results of information system vulnerability hazard level assessment model

IV. The Construction of Information System Vulnerability Knowledge Graph and Intelligent Retrieval System for Similar Vulnerabilities

A. Knowledge Graph of Information System Vulnerabilities

This study presents three steps for constructing a knowledge graph of information system vulnerabilities: knowledge graph design, entity recognition, relationship extraction, and knowledge graph storage.

1) Knowledge Graph Design: In the knowledge graph design stage, this article defines eight types of entities in the knowledge graph: vulnerability category, vulnerability ID, vulnerability hazard level, vulnerability detailed description, vulnerability proof, vulnerability solution, set of entities involved in the vulnerability, and entities involved in the vulnerability. The knowledge graph structure designed in this study is shown in Figure 5.

2) Entity recognition: In the stage of entity recognition, the entities to be extracted are companies, institutions, organizations, locations, and other entities involved in the vulnerability. Therefore, this article chose the "resume NER" dataset. There are 321 countries, 1076 institutions, 55 locations, 1174 individuals, 5687 organizations, 338 professions, 144 ethnic groups, and 7770 professional titles labeled in the dataset.

This dataset adopts the "BMEO" annotation rule, where "B-entity category" represents the beginning of this type of entity, "M-entity category" represents the middle of this type of entity, and "E-entity category" represents the end of this type of entity. "O" represents that the word does not constitute an entity.

Authorized licensed use limited to: Thammasat University. Downloaded on August 07,2026 at 05:03:11 UTC from IEEE Xplore. Restrictions apply.

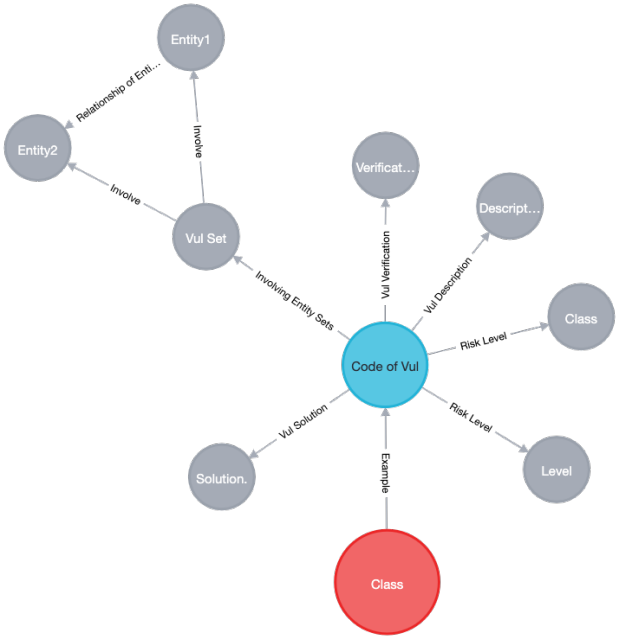


Fig. 5. Schematic diagram of knowledge graph structure

This article constructed a BiLSTM-CRF model for entity recognition. The BiLSTM model can divide the entity recognition sequence annotation task into multiple classification problems. Due to its bidirectional structure, BiLSTM can capture bidirectional semantic dependencies in text processing, resulting in better performance in tasks that require consideration of contextual relationships. However, due to the model's inability to detect the relationship between output labels, it may lead to logical errors in the labeling process. Therefore, by integrating BiLSTM with CRF models and utilizing the feature that CRF models can learn regular constraints in sentences, these constraints are added to the output results of BiLSTM to ensure that the final annotation results are effective, thereby further improving the performance of the model in entity recognition.

During the construction process, the hyperparameters of the model set in this article include 128 dimensions for word vectors, 128 dimensions for hidden vectors, batch size 64, learning rate 0.001, and epochs 30.

To evaluate the performance of the model, this article uses the following three metrics: accuracy, recall, and F1. This study trained and evaluated the BiLSTM-CRF model using the resume NER dataset. As a comparison, this article also constructed and trained both Hidden Markov Model (HMM) and BiLSTM models. After completing the training of the three models, this study evaluated the models using the above three metrics, and the final experimental results are shown in Table I.

From the experimental results, the BiLSTM-CRF model performs the best with a prediction accuracy of 95.74%. Therefore, this paper selects the BiLSTM-CRF model to extract entities from the text data of detailed vulnerability description, vulnerability proof, and vulnerability resolution in the reports of information system vulnerabilities. At the same time, to improve the entity recognition rate and comprehensiveness, this article not only uses the trained model, but also uses the LTP entity recognition tool developed by Harbin Institute of Technology to identify entities in the information system vulnerability report dataset, which includes detailed vulnerability descriptions, vulnerability proofs, and vulnerability resolution methods. After the recognition is completed, this article integrates the entities recognized by the two models. According to statistics, a total of 1893 entities were extracted from the two models.

TABLE I. EXPERIMENTAL RESULTS OF ENTITY RECOGNITION MODEL

	Precision	Recall	F1 Score
HMM	0.9149	0.9122	0.913
BiLSTM	0.9519	0.9516	0.9513
BiLSTM-CRF	0.9574	0.957	0.9569

After entity recognition, this study used the Jiagu Chinese relation extraction tool to extract the relationships between these entities existing in the text. This article extracts 422 sets of relationships from the detailed description text, proof text, and solution text of vulnerabilities in the dataset. The extraction result is saved in the xls file as a triplet of "[entity 1, relationship, entity 2]".

Afterward, this article configured the Neo4j graph database and used the xlrd package in Python to read the entities and relationships stored in xls files. The py2neo package was used to write these entities and relationships into the Neo4j graph database and construct a knowledge graph. The knowledge graph constructed in this article includes 59783 nodes, 59679 edges, and 56 relationships, as shown in Figure 6.

B. Intelligent Retrieval System for Similar Vulnerabilities Based on Knowledge Graph

1) System architecture design: The system architecture consists of two parts: the layer for information system vulnerability analysis and the layer for application service. In the information system vulnerability analysis layer, the system utilizes the BERT-based information system vulnerability classification model constructed earlier to classify the input vulnerability descriptions and uses the BERT-based information system vulnerability hazard assessment model constructed earlier to predict the hazard level of the vulnerability input. After completing these two tasks, the information system vulnerability analysis layer will use the entity recognition model constructed in this article to extract the entities involved in the input vulnerability description, and use the predicted category, predicted hazard level, and entity identified in the vulnerability description to query vulnerabilities of the same category, hazard level, and entity in the information system vulnerability knowledge graph.

The application service layer interacts with users. This layer hands over the vulnerability description entered by the user to the information system vulnerability analysis layer for parsing and feeds back the similar vulnerability ID and information obtained after parsing to the user.

Authorized licensed use limited to: Thammasat University. Downloaded on August 07,2026 at 05:03:11 UTC from IEEE Xplore. Restrictions apply.

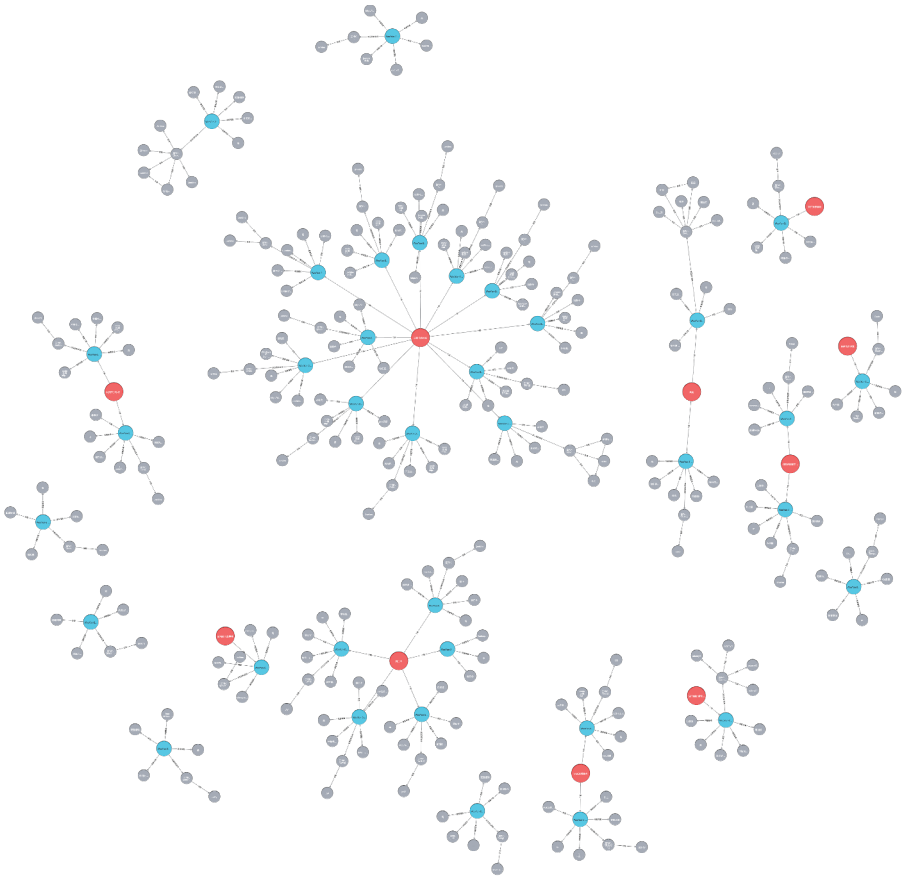


Fig. 6. Part of Knowledge Graph of Information System Vulnerabilities

2) System workflow and display: The first page after entering the system is shown in Figure 7. Below the system is an input box for describing system vulnerabilities. The box for inputting vulnerability description is down the page. After entering the system, users can enter a description of the system vulnerability in the input box. There is a send button for vulnerability description on the right side of the input box. After entering the vulnerability description, the user clicks the send button, and the system can submit the vulnerability description to the information system vulnerability analysis layer for analysis.

After the completion of the vulnerability analysis layer in the information system, the system will display the predicted vulnerability hazard level, vulnerability type, similar vulnerability ID, and detailed information on similar vulnerabilities, as shown in Figure 8. Users can click on the similar vulnerability ID on the left, and the system will display the information about this similar vulnerability on the right side.

V. Conclusion and Future Work

To address issues like vulnerabilities in information systems, this study collected information system vulnerability report data, built a BERT-based model for classification and hazard level prediction of information system vulnerabilities, and then constructed a knowledge graph for information system vulnerabilities. After that, this study integrates the results of the above work and constructs an intelligent retrieval system for similar vulnerabilities based on knowledge graphs.

In the future, we will collect information system vulnerability report data more comprehensively, from multiple data sources, to provide users with more accurate and enrich similar vulnerability information references. In addition, we will further study how to determine the similarity between vulnerabilities to improve the accuracy and effectiveness of intelligent retrieval of similar vulnerabilities.



Fig. 7. Intelligent retrieval system for similar vulnerabilities

Authorized licensed use limited to: Thammasat University. Downloaded on August 07,2026 at 05:03:11 UTC from IEEE Xplore. Restrictions apply.



Fig. 8. Intelligent Retrieval System for Similar Vulnerabilities After retrieving

VI. Acknowledgement

This research is supported by grants from Beijing Social Science Foundation (Grant 23GLB012). Xiong Zhang (xiongzhang@bjtu.edu.cn) is the corresponding author.

References

[1] Xiong Zhang, Haoran Xie, Hao Yang, Hongkai Shao, Minghao Zhu, "A General Framework to Understand Vulnerabilities in Information Systems", IEEE Access, 2020, vol. 8, pp. 121858-121873, doi: 10.1109/ACCESS.2020.3006361.

[2] Xiong Zhang, Alex Tsang, Wei Thoo Yue, Michael Chau, "The Classification of Hackers by Knowledge Exchange Behaviors", Information Systems Frontiers, 2015, vol. 17 no. 6, pp. 1239-1251 doi: 10.1007/s10796-015-9567-0.

[3] P. Mell, K. Scarfone, and S. Romanosky, "Common Vulnerability Scoring System," IEEE Security and Privacy Magazine, vol. 4, no. 6, pp. 85–89, Nov. 2006, doi: 10.1109/MSP.2006.145.

[4] P. Mell and K. Scarfone, "A complete guide to the common vulnerability scoring system version 2.0.1," First-Forum of incident response and security teams, 2007.

[5] C. Fruhwirth and T. Mannisto, "Improving CVSS-based vulnerability prioritization and response with context information," in 2009 3rd International Symposium on Empirical Software Engineering and Measurement, IEEE, Oct. 2009, pp. 535–544. doi: 10.1109/ESEM.2009.5314230.

[6] K. A. Farris, A. Shah, G. Cybenko, R. Ganesan, and S. Jajodia, "VULCON," ACM Transactions on Privacy and Security, vol. 21, no. 4, pp. 1–28, Nov. 2018, doi: 10.1145/3196884.

[7] M. A. McQueen, T. A. McQueen, W. F. Boyer, and M. R. Chaffin, "Empirical Estimates and Observations of 0Day Vulnerabilities," in 2009 42nd Hawaii International Conference on System Sciences, IEEE, 2009, pp. 1–12. doi: 10.1109/HICSS.2009.186.

[8] Xiong Zhang, Hongkai Shao, Minghao Zhu and Runtong Zhang, "Towards Understanding Vulnerability in Information Systems: The Topic Modeling Perspective", Twenty-Fourth Pacific Asia Conference on Information Systems (PACIS 2020), Dubai, UAE, Jun. 2020, pp. 20-24 doi: https://aisel.aisnet.org/pacis2020/242.

[9] Xiong Zhang, Wei Thoo Yue, "Integration of On-Premises and Cloud-Based Software: The Product Bundling Perspective", Journal of the Association for Information Systems, 2020, vol. 21 no.6, Article 6.

[10] B. Shuai, H. Li, M. Li, Q. Zhang, and C. Tang, "Automatic classification for vulnerability based on machine learning," 2013 IEEE International Conference on Information and Automation, ICIA 2013, pp. 312–318, 2013, doi: 10.1109/ICInfA.2013.6720316.

[11] M. Davari, M. Zulkernine, and F. Jaafar, "An Automatic Software Vulnerability Classification Framework," Proceedings - 2017 International Conference on Software Security and Assurance, ICSSA 2017, pp. 44–49, Jun. 2018, doi: 10.1109/ICSSA.2017.27.

[12] Z. Han, X. Li, Z. Xing, H. Liu, and Z. Feng, "Learning to predict severity of software vulnerability using only vulnerability description," Proceedings - 2017 IEEE International Conference on Software Maintenance and Evolution, ICSME 2017, pp. 125–136, Nov. 2017, doi: 10.1109/ICSME.2017.52.

[13] Shiyun Hao, Weihua Li and Xiong Zhang, "Investigating Information Systems Vulnerabilities Using Machine Learning Algorithms", 23rd International Conference on Electronic Business (ICEB 2023), Chiayi, Taiwan, China, Oct. 2023, pp. 19-23.

[14] Z. Han, X. Li, H. Liu, Z. Xing, and Z. Feng, "DeepWeak: Reasoning common software weaknesses via knowledge graph embedding," in 2018 IEEE 25th International Conference on Software Analysis, Evolution and Reengineering (SANER), IEEE, Mar. 2018, pp. 456–466. doi: 10.1109/SANER.2018.8330232.

[15] S. Qin and K. P. Chow, "Automatic Analysis and Reasoning Based on Vulnerability Knowledge Graph," 2019, pp. 3–19. doi: 10.1007/978-981-15-1922-2_1.

Authorized licensed use limited to: Thammasat University. Downloaded on August 07,2026 at 05:03:11 UTC from IEEE Xplore. Restrictions apply.